

腾讯安全 | 腾讯安全云鼎实验室

模型有界 安全无疆

腾讯安全沙龙第2期（西安站）



关于我

About me

ABC_123, 公众号"希潭实验室"原创作者。2008年入行网络安全, 曾连续八年参加国家级网络安全攻防比赛。十九大网络安全保卫局优秀个人, 某部HWBP、CCSS授课讲师, 某市网信办攻防演习专家裁判, 某市公安局重保网络安全专家, 某市网信办/公安优秀攻击队员。

曾受邀在首届华为漏洞管理与应急响应技术大会、北京工商银行、某头部安全企业等, 分享《APT攻击追踪与企业安全风险防范》专题。Struts2漏洞检测、Weblogic反序列化等红队工具原创作者, 擅长安全咨询、红队攻防、APT技战法分析、Java代码审计、内网渗透及网络安全培训等。

AI在APT追踪与防御中的应用

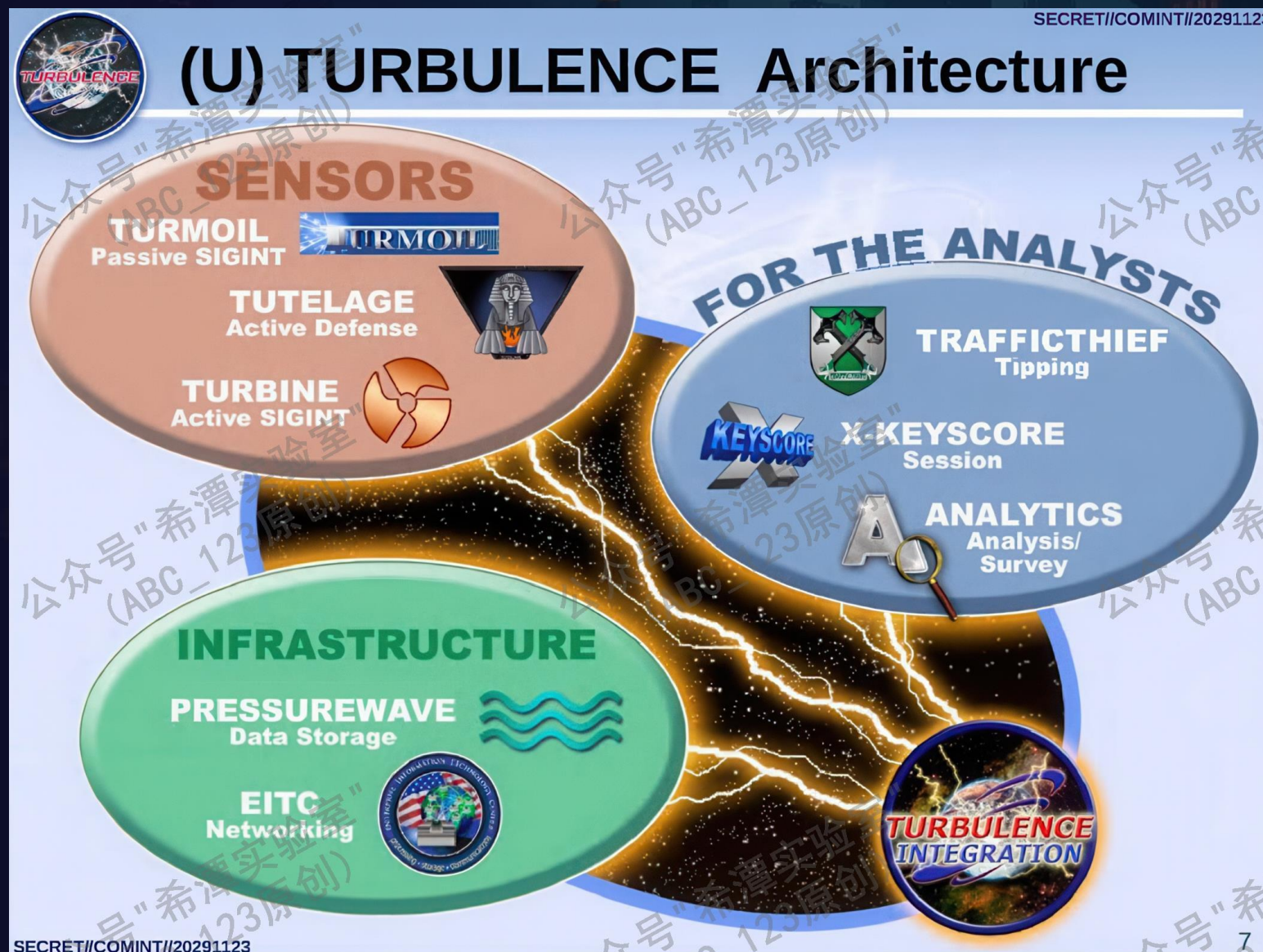
- 1 美国国家安全局网络空间安全主动防御体系
- 2 俄罗斯APT的Solarwinds供应链攻击
- 3 传统方法及机器学习对DGA域名的识别

1 美国国家网络安全局网络空间安全主动防御体系



美国NSA的Turbulence系统

Turbulence/'tɜːrbjələns/'
“湍流”系统是NSA用于大规模数据存储和分析的一个平台，目的是处理全球范围内的数据流，包括互联网流量、电话记录等。它能够帮助NSA在不同的网络和通信系统中追踪目标，并整合多种情报源的数据进行分析。Turbulence也与其他NSA的工具互联，形成了一个庞大的情报收集系统。



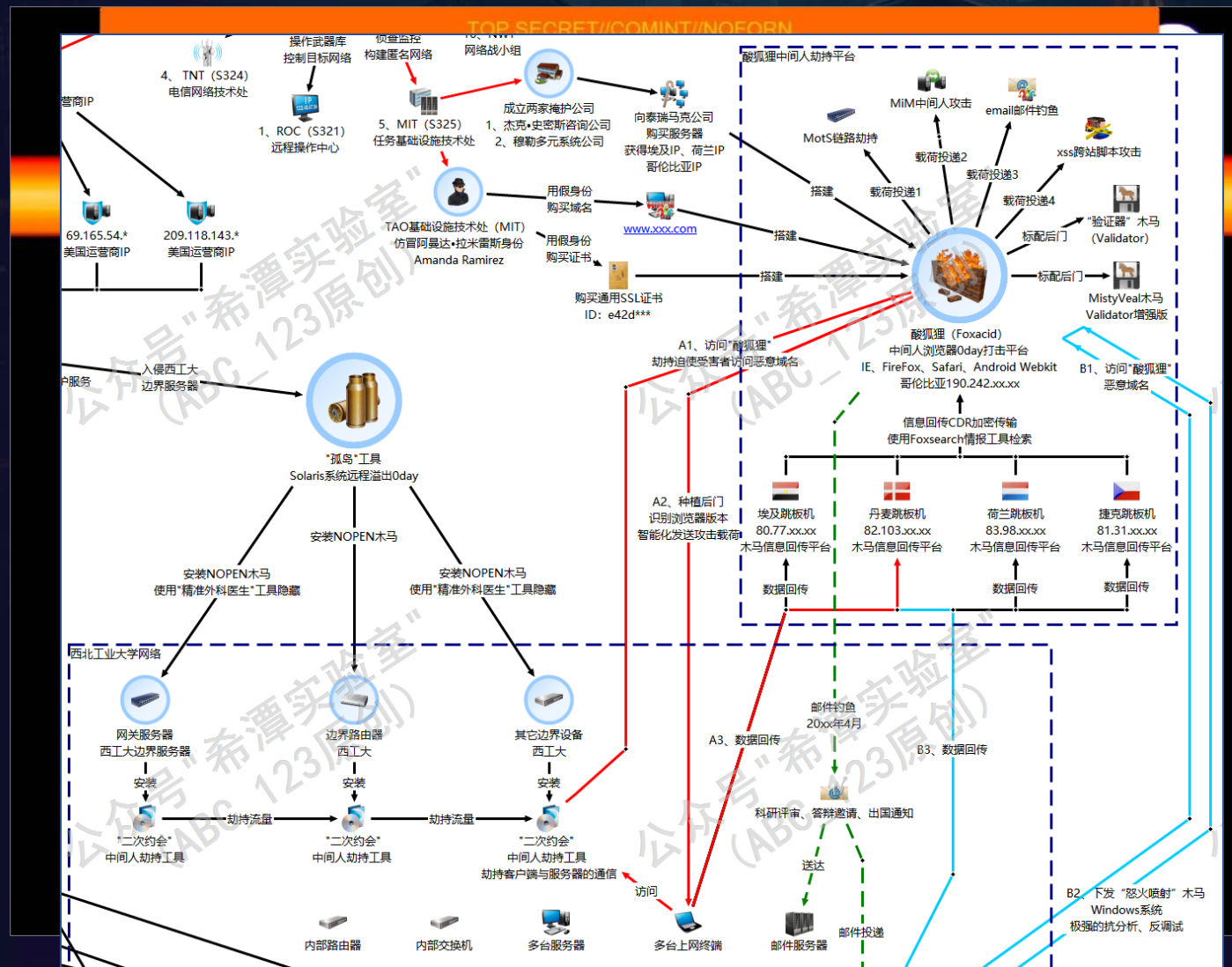
“酸狐狸” 0day漏洞攻击平台 (FoxAcid)

2007年开始投入运作，对于中国、俄罗斯会有专门的定制版。
集合了各种浏览器0day漏洞IE、Firefox、Chrome、苹果Safari、安卓Webkit、Flash等。

结合二次约会中间人劫持工具，迫使用户访问酸狐狸攻击平台的恶意url地址。
NSA把代号为“量子”的服务器放在Internet骨干网。

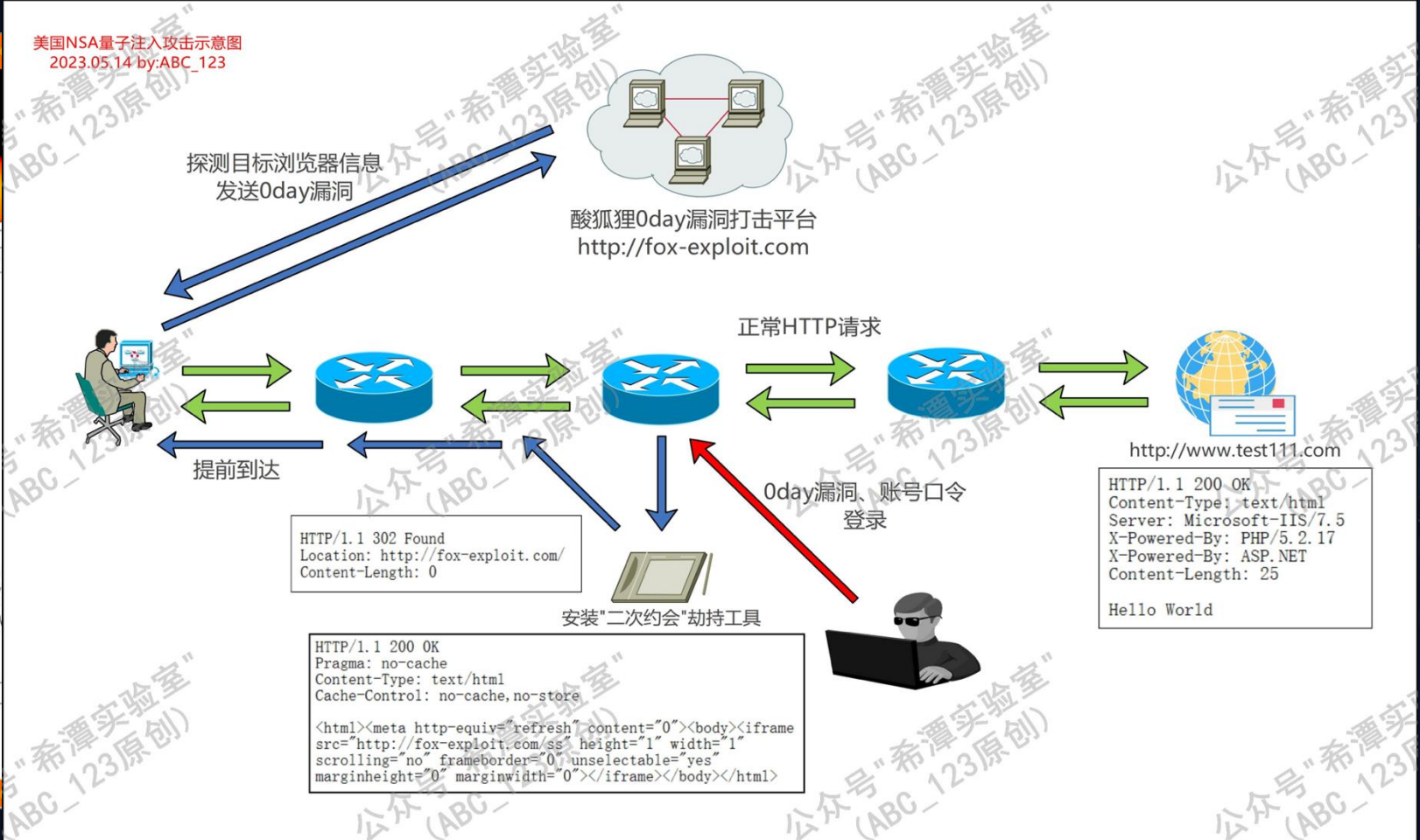
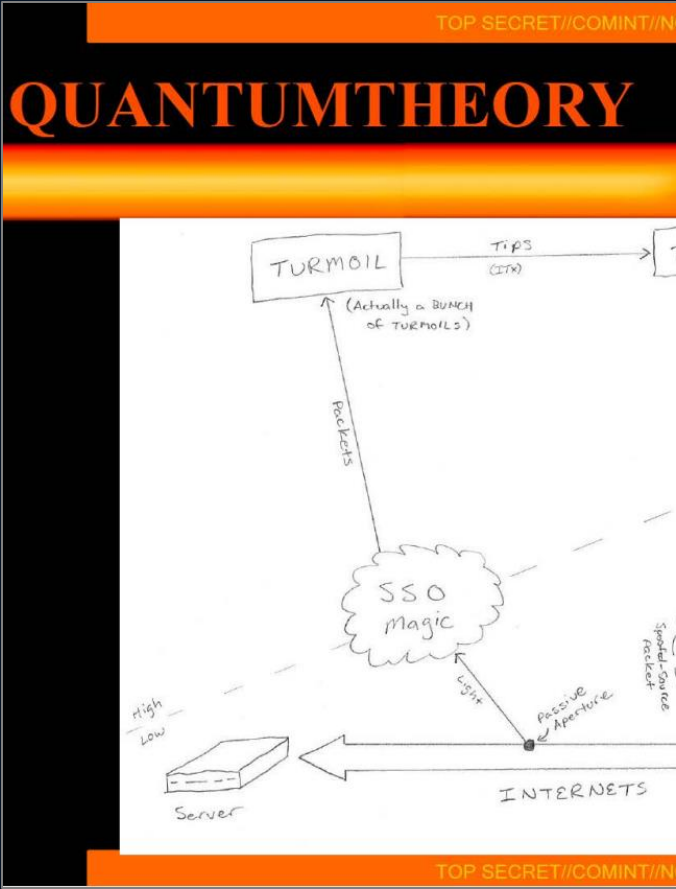
直接访问FoxAcid平台不会有攻击，需要访问到专门的url。

目标价值高，会选用价值高0day；目标价值低，会选用价值低的0day；而目标防护高，为了保住0day会采用1day或nday。



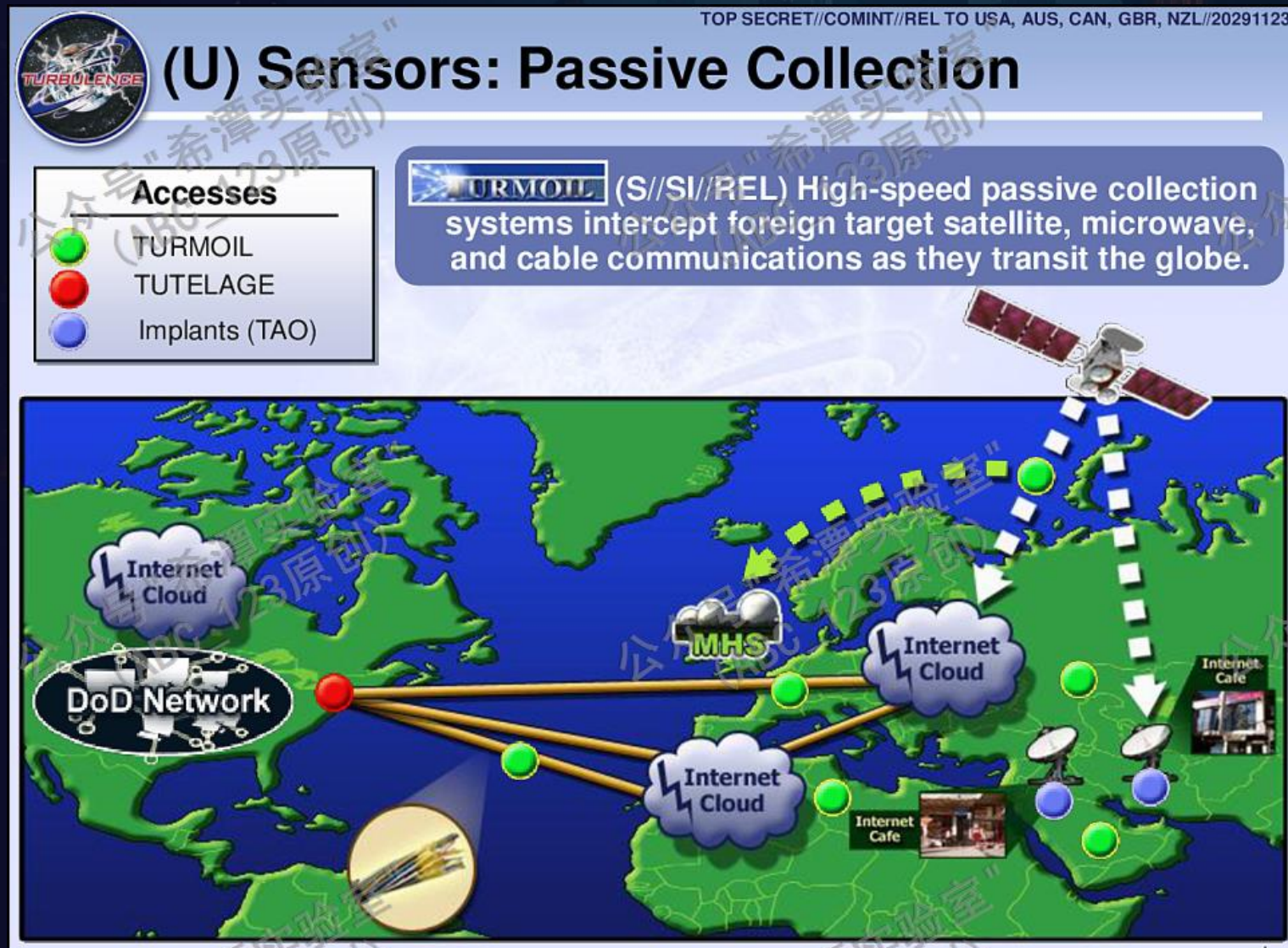
量子注入攻击原理及特征

利用时间差，比正常网页返回提前达到目标，迫使浏览器用户302重定向访问“酸狐狸” 0day漏洞攻击平台。



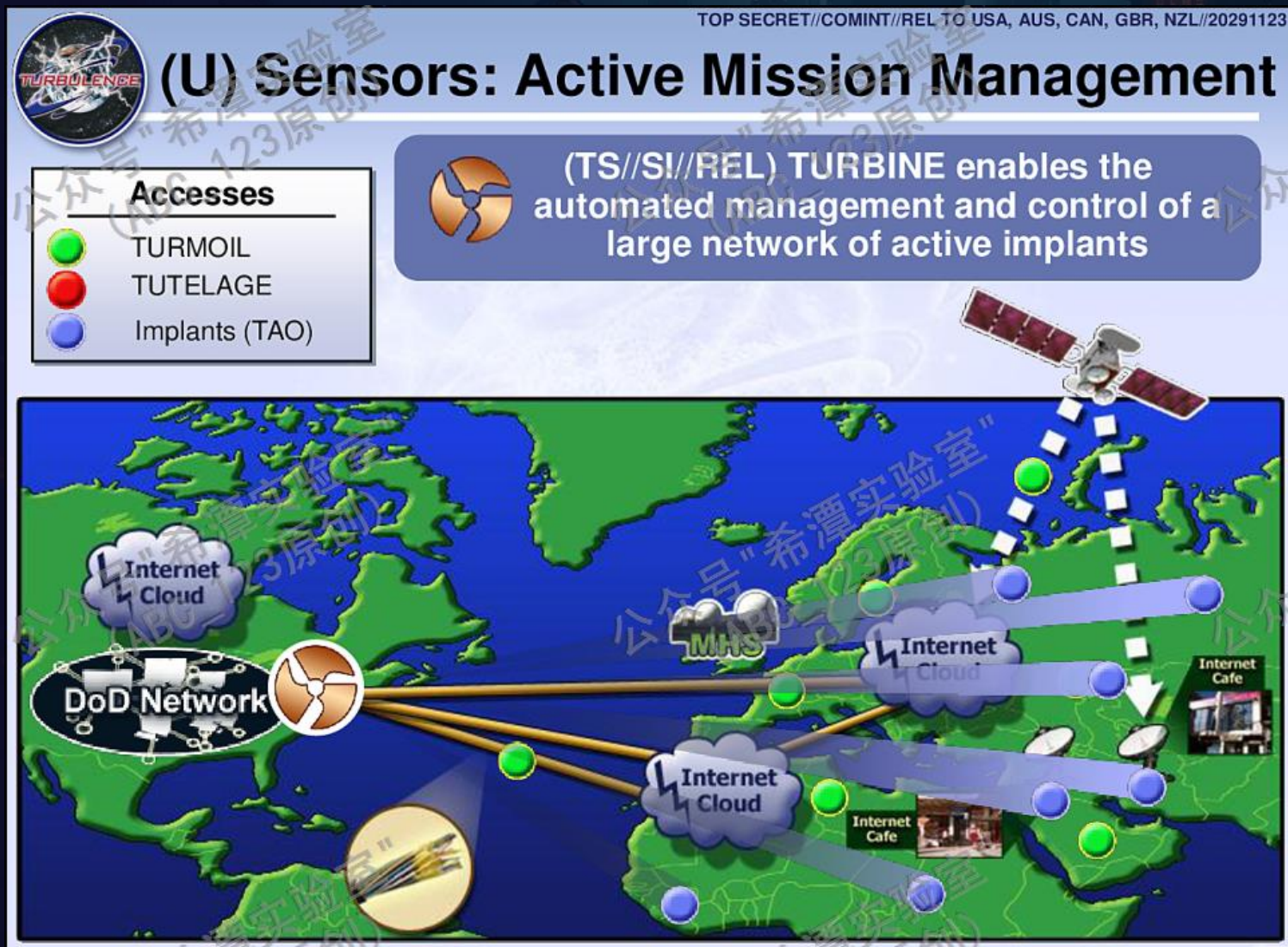
Turmoil被动监听系统

Turmoil在国内文章被翻译为“混乱”，它由分布在全球各个网络关键节点的数据监视传感器组成；Turmoil被描述为“快速、被动的收集系统，用于捕捉通过世界发送的卫星、微波和电缆通信”，通过被动监听的方式，持续不断地监视和采集全球网络中传输的各种敏感数据。Turmoil在数据包层面上进行操作，通过特殊技术手段可以分析VPN和VoIP加密流量；它根据“选择器(selector)”对互联网流量中有价值的数据信息进行识别和筛选，这些分拣器用于判断目标用户是否在使用谷歌、雅虎、脸书、skype等，一旦识别到重要的目标，将会触发Turbine（涡轮）系统进行下一步操作。



Turbine主动攻击系统

Turbine是主动数据窃取系统，通常与Turmoil（混乱）系统协作，主要功能为将恶意软件植入目标机器。当Turbine接收到Turmoil系统的消息通知，首先会对Turmoil提交的内容作进一步判定，如果判定是重要目标，会在一秒钟内将流量转发到美国TAO的网络节点（如部署在互联网骨干节点的酸狐狸0day攻击平台），使用不同的量子注入攻击方法（包括量子DNS攻击手段等）获取目标计算机权限。Turbine也提供了图形界面，方便NSA的工作人员手工进行选择、定位和发布任务。不同国家不同地区的Turmoil节点发现了有价值目标或者攻击流量，通过消息通知Turbine，Turbine涡轮系统对这些重要目标的流量返回包重定向到美国TAO的攻击平台，攻击平台利用漏洞下发Implants（木马植入），获取目标机器权限。



Turmoil与Turbine系统协作

第1步 普通用户打开浏览器访问Facebook网站等待Facebook返回网页内容。

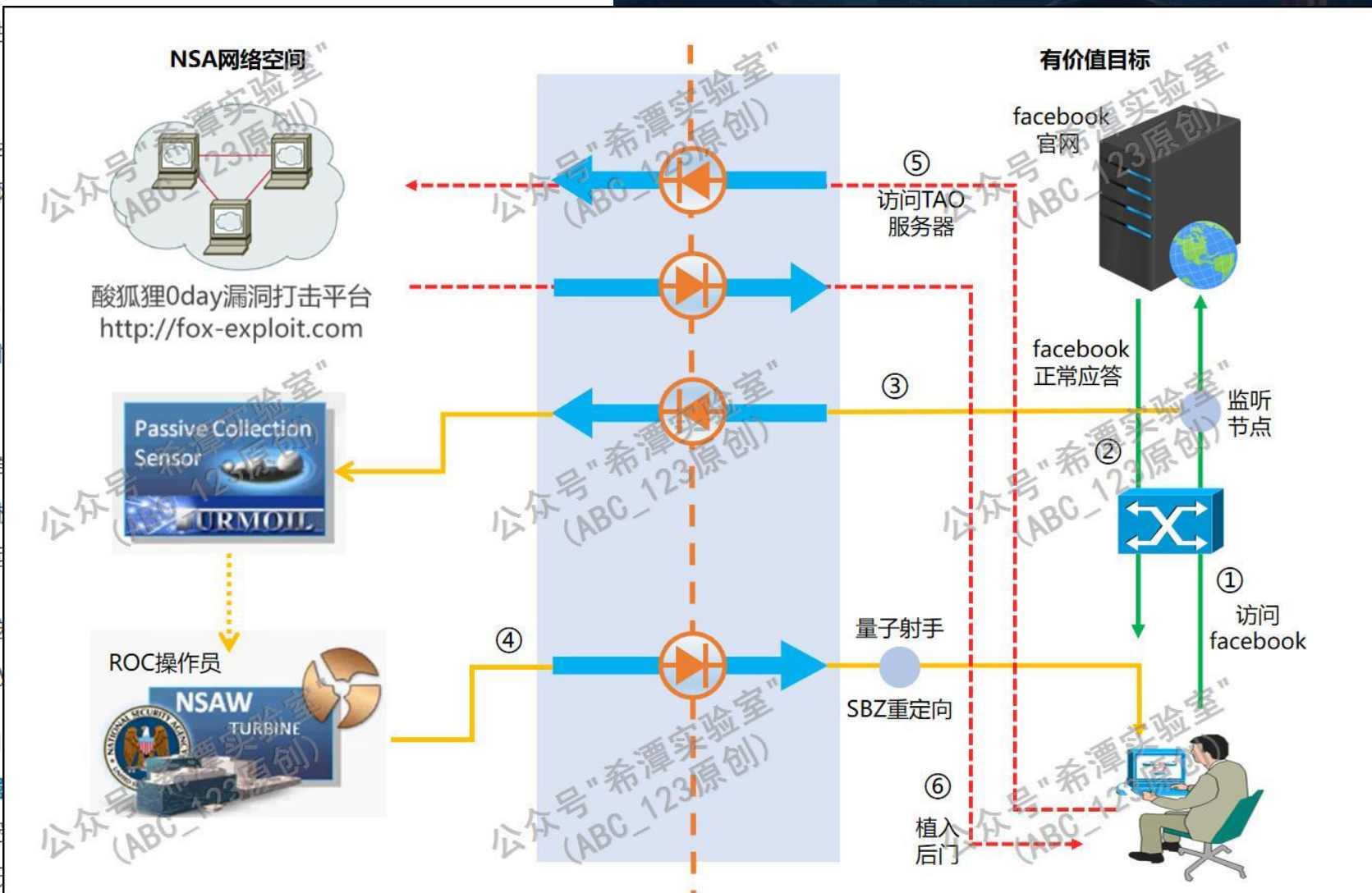
第2步 Facebook官网返回正常的应答包，将Facebook返回的数据进行渲染，为用户展示出漂亮的网络流量走向情况。

第3步 在正常用户的请求数据包到达Facebook，它通过各种**分拣器**发现了该浏览Facebook网站的行为，系统下发消息通知。

第4步 Turbine系统进一步判断该目标确实是有得到一个安装了**SBZ后门**的被称为**"量子射手"**的跳板包，这个数据包会先于Facebook网站的正常返回

第5步 受害者浏览器首先接收到了SBZ后门发送的访问了美国NSA的TAO恶意网站，如酸狐狸0day

第6步 美国NSA的TAO恶意网站通过浏览器0day漏洞获取受害者计算器权限，然后植入**Validator**验证器，以通过植入的后门记录受害者的键盘输入、收集系统信息、窃取网络流量、记录屏幕截图、录制音频、控制电脑摄像头拍摄照片、记录受害者每天



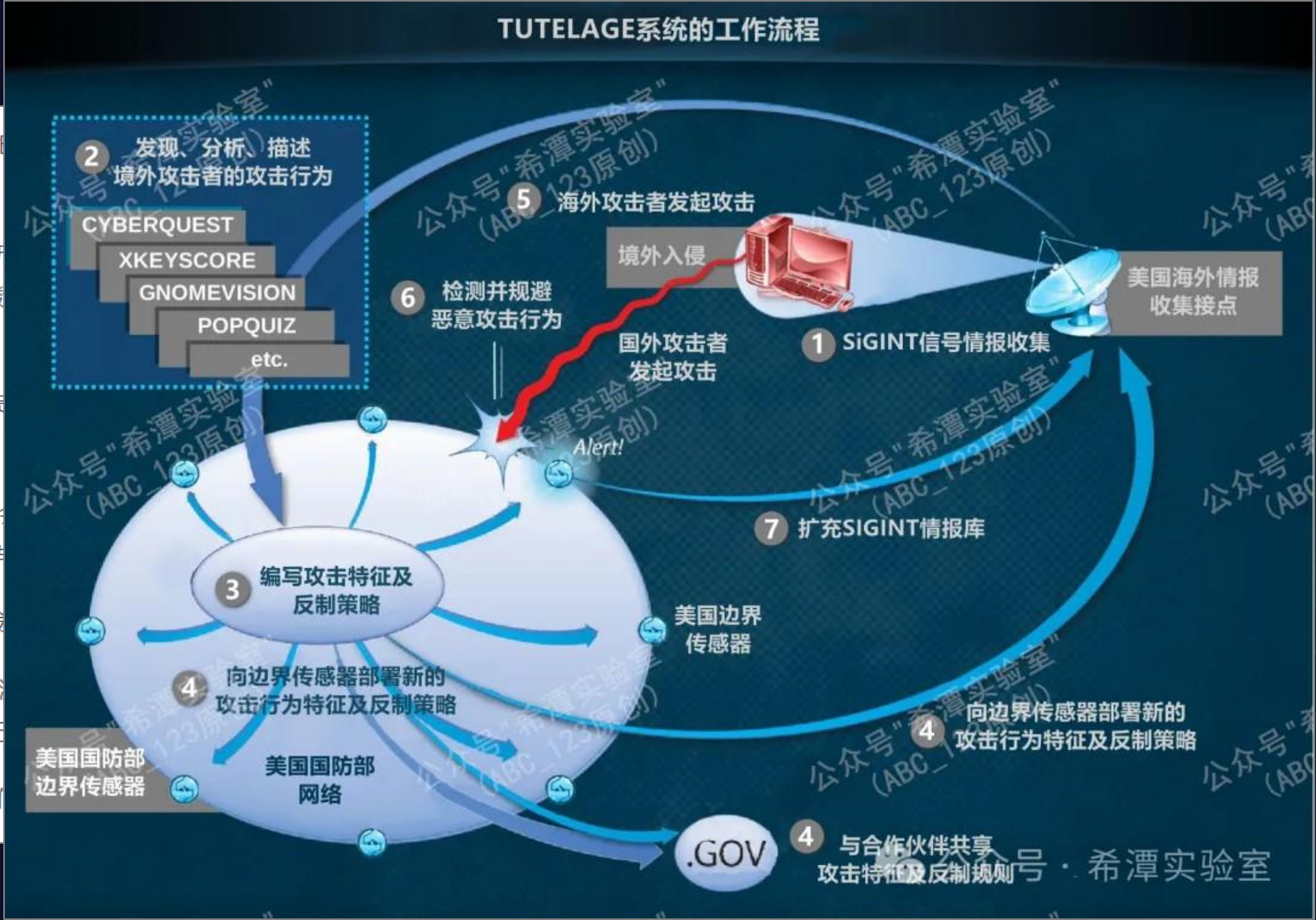
TUTELAGE基本介绍

TUTELAGE应用部署在国防部(简称DoD)网络边界上,称为边界传感器(Boundary sensor)对来自因特网的信息进行监测,从而保护内部应用非安全性互联网协议路由(简称NIPR)的网络。图中展示了TUTELAGE系统的10个边界传感器所在位置,其中包括hickam美国空军基地、Beale美国空军基地、圣安东尼奥军事基地、诺福克海军基地、五角大楼(Pentagon)、日本横田美国空军基地。



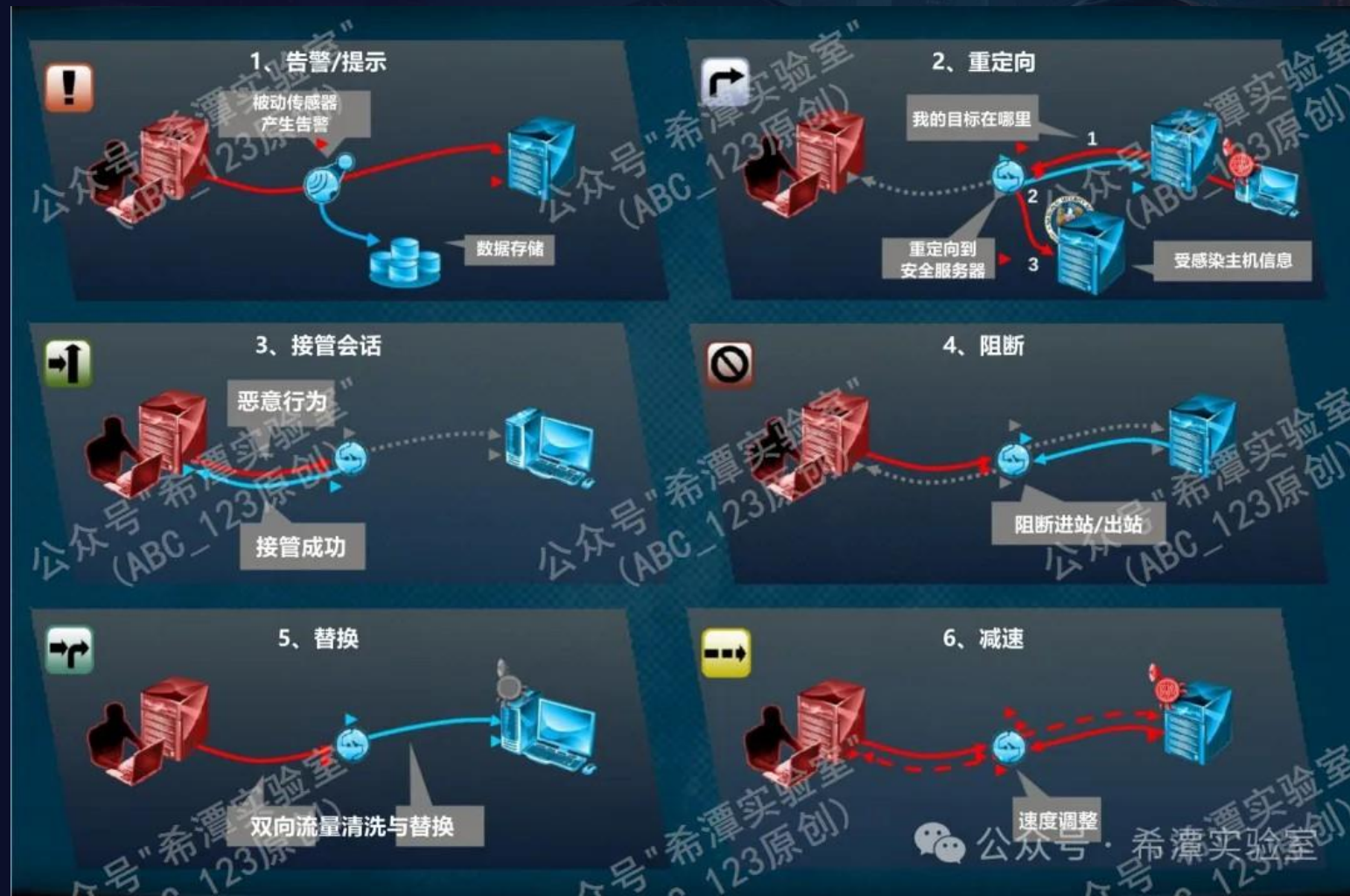
TUTELAGE系统的防御思路

- 1 SIGINT信号情报收集。**美国NSA的SIGINT信号情报收集系统，著名的“棱镜门”监听事件也与其有关。
- 2 发现境外攻击者的入侵意图。**美国NSA通过各种分析工具（如XKEYSCORE、GNOMEVISION、POPQUIZ等，对海量情报数据进行筛选和分类。
- 3 行为特征提炼及反制策略编写。**美国NSA的工作人员根据收集到的情报，提炼攻击者的行为特征，并编写攻击反制规则。
- 4 下发策略到TUTELAGE系统。**美国NSA的工作人员将编写好的反制策略下发到美国国防部DoD的网络边界的TUTELAGE传感器上，并同时与美国国防部网络进行连接。
- 5 境外攻击者发动网络攻击。**一段时间后攻击者开始发动攻击。
- 6 TUTELAGE系统反制。**TUTELAGE的边界传感器检测到攻击行为，TUTELAGE系统依据不同情况，通过不同的反制措施进行反制。
- 7 汇总攻击信息。**将整个网络攻击情报反馈到SIGINT情报收集系统。



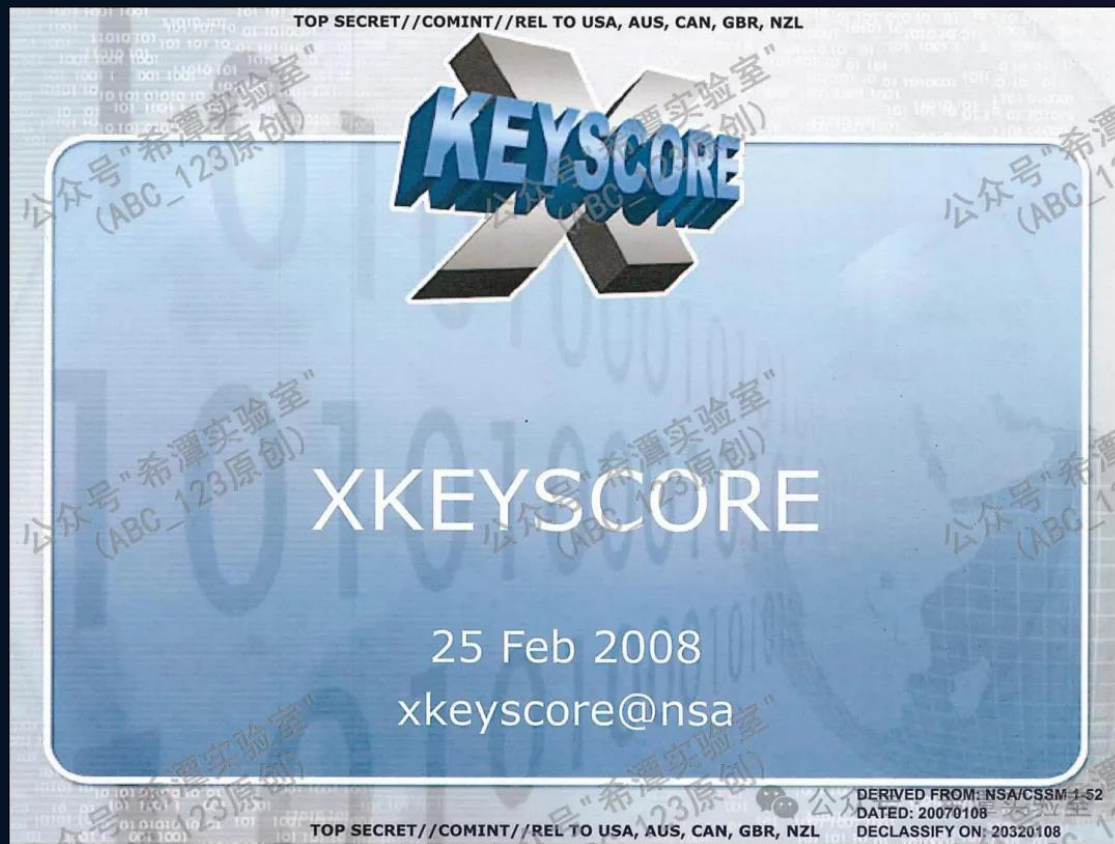
TUTELAGE系统的反制措施

告警/提示
重定向
接管会话
阻断
替换
减速



美国NSA全球个人信息检索系统 XkeyScore

XKeyscore国内翻译为“关键得分”，早在2008年就已经投入使用，是美国NSA研发的功能非常强大的情报分析系统，也可以理解为一个强大的数据库，由部署在全球各个节点的Linux集群构成。美国APT工作人员可以使用XKeyscore完成各种操作：查找与犯罪事件、间谍事件相关联的人员信息，比如使用语言不是所在地区的人、使用加密通信技术的人、搜索网络中可疑的犯罪分子。



美国NSA全球个人信息检索系统 XkeyScore

Home MyXKS Admin Users Search Workflow Central Results Fingerprints Tagging Statistics Tasking Map Help

Note: Icons on this page represent categories of services (e.g. web searches, VoIP, browsers) provided by established commercial firms. They do NOT identify targeted firms.

Navigation: IP Address: [REDACTED] Country: PK City: KARACHI Start: 2012-04-27 14:00 Stop: 2012-04-27 14:00 HHFP: 13c8eaa4

Fingerprint: defeat/router/yahoo/insider/client.ad.get defeat/atks/yahoo/insider/client.ad.get endpoint/related/atomiconkey372/nachinold/mso/cne/simbar mail/webmail/yahoo

Active Accounts: User [REDACTED] <yahooBcookie>

All Accounts: User [REDACTED] Role: unknown State: active

Web Sites Visited: Type Page Title/Host host insider.msg.yahoo.com host us.adserver.yahoo.com

Web Searches: Targets: Content Hits Device Information: Client IP [REDACTED] Client GE [REDACTED] PK, KARACHI

X-KEYSCORE C2C Session Viewer

Session: 38 of 134

From IP: 193. [REDACTED] To IP: 217. [REDACTED] From Port: 50423 To Port: 80 Protocol: TCP

Session Header (3) Meta (6)

Quick Clicks: One-Click Searches: Find opposite side of sess Find traffic on Find application Find proxy hash Find x-forwarded-for IP

Display Information: HTTP-GET

GET /load_users.php HTTP/1.0

Accept: image/gif, image/x-bitmap, image/jpeg, image/pjpeg, application/x-shockwave-flash, application/vnd.ms-powerpoint, application/vnd.ms-excel, application/msword, */*

Referer: http://wvisa.mfa.gov.ir/logo_top_user.php

Accept-Language: fa

Accept-Encoding: gzip, deflate

User-Agent: Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; SV1)

Host: wvisa.mfa.gov.ir

Cookie: azhans_name=... azhans_user=[REDACTED] azhans_pass=[REDACTED] azhans_serial=user user=THR username=... place=deleted famul=deleted utma=238135644.2300981863224871400.1239874722.1243255420.1107685748.4 utmz=238135644.1107685748.4.4.utmcsr=fardanews.com|utmccn=(referral)|utmcmd=referral|utmcet=/fa/pages/links.php

Via: 1.1 centremounainternet-cache.com:3128 (squid/2.6.STABLE16)

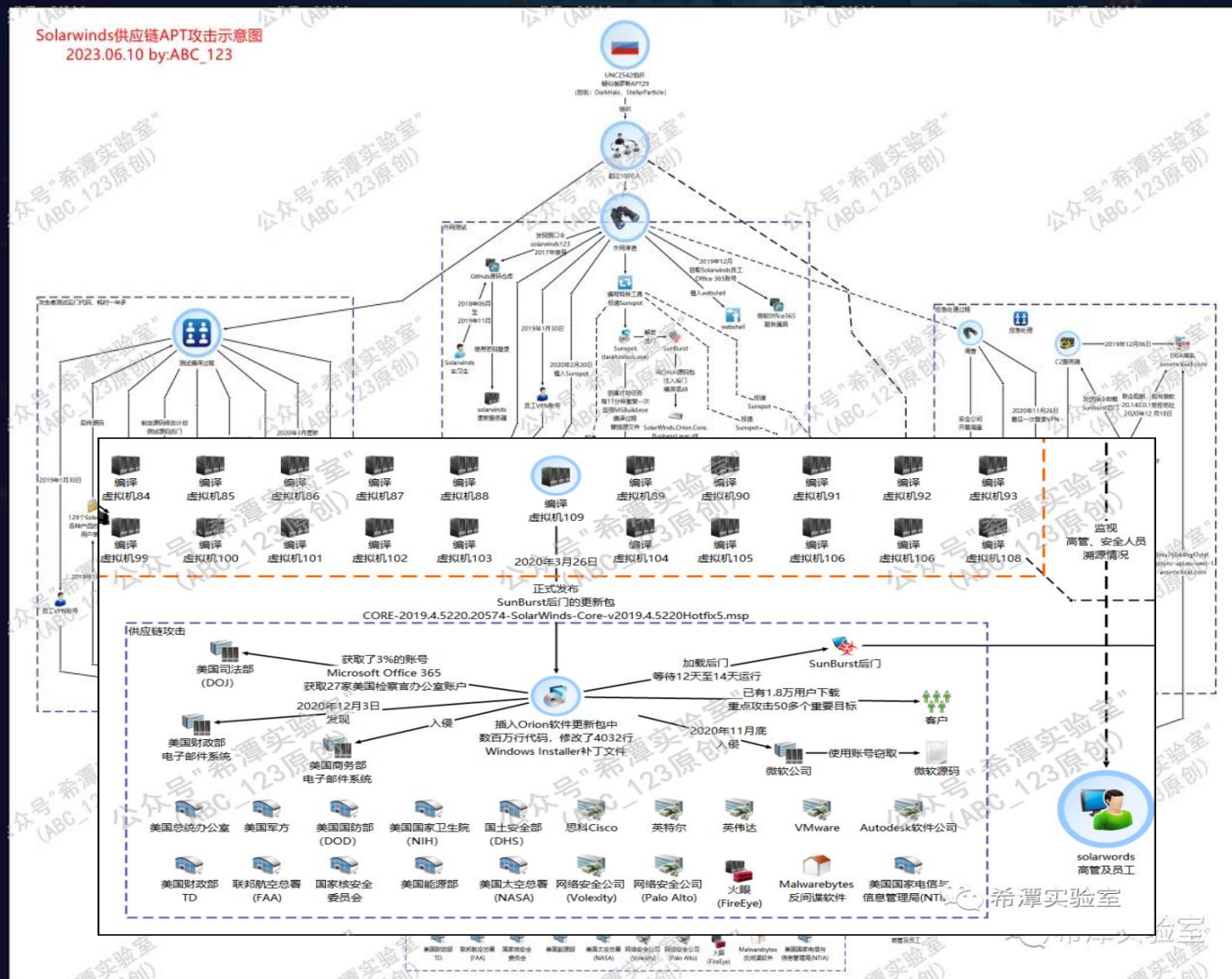
X-Forwarded-For: 193. [REDACTED]

2 俄罗斯APT的Solarwinds供应链攻击

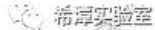
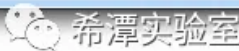
各种APT手段突破美国NSA构建的防御系统，且无感知无告警

上游供应链投毒风险 (Solarwinds攻击案例)

国内跨国公司的采购环节，上游供应链环境。在Orion/ə'raɪ.ən/网管软件源码编译过程中植入测试后门代码。攻击过程：攻击者首先入侵了A国Solarwinds/'sou.lər.wɪndz/网络管理软件公司内网，接着获取了所有源码编译服务器的权限，通过编写的Sunspot/'sʌn.spɒt/工具（一款后门投递及源码修改工具）监视旗下Orion网管软件更新包的源码编译过程，从源码层面植入Sunburst后门程序，编译后自带Solarwinds合法数字签名Solarwinds Worldwide, LLC，这种方式自带白名单效果，完美绕过各种防护措施。等到Solarwinds官方下发软件更新包后，导致旗下数万家Orion客户公司内网沦陷。挑选100多家重点单位入侵。Sunburst后门通信逃过了A国耗时十多年、花费数百亿美元建造的网络攻击防御系统“爱因斯坦”（Einstein），此APT的前期准备耗时一年。



名



Sunburst后门：dga域名通信阶段

Sunburst使用的dga域名做了非常巧妙的处理，大致格式如下：

- *.appsync-api.eu-west-1.avsvmcloud.com (*代表DGA的子域名)
- *.appsync-api.us-west-2.avsvmcloud.com (*代表DGA的子域名)
- *.appsync-api.us-east-1.avsvmcloud.com (*代表DGA的子域名)
- *.appsync-api.us-east-2.avsvmcloud.com (*代表DGA的子域名)

其中，每个DGA域名右边三个分段，来自于后门程序中硬编码的字符串，而dga域名的第一分段的星号部分是根据受害者服务器中的计算机域名等信息动态生成的，以下是一个DGA阶段域名生成算法的示例。

第1分段	第2分段	第3分段	第4分段
3mu76044hgf7shjf.	appsync-api.	eu-west-1. us-west-2. us-east-1. us-east-2.	avsvmcloud.com
根据受害者的计算机域名等基础信息加密生成	固定不变的值	以上4选1	固定不变的二级域名

Sunburst后门：dga域名通信阶段

第1步 2020-06-11 04:00 UTC

Sunburst发起查询：r8stkst71ebqgj66ervisu10bdohu0gt.appsync-api.us-west-2.avsvmcloud.com ⇒ AD 域，C2攻击者得到第 1 部分内容“central.pima.g”
响应：8.18.144.1 ⇒ Sunburst后门休眠 1 小时，然后继续。

第2步 2020-06-11 05:00 UTC

Sunburst发起查询：ulfmcf44qd58t9e82w.appsync-api.us-west-2.avsvmcloud.com ⇒ 域，C2攻击者得到第 2 部分“ov”
响应：8.18.144.2 ⇒ Sunburst后门休眠 1 小时，然后继续（此时攻击者知道了目标计算机的名是central.pima.gov）。

第3步 2020-06-11 06:00 UTC

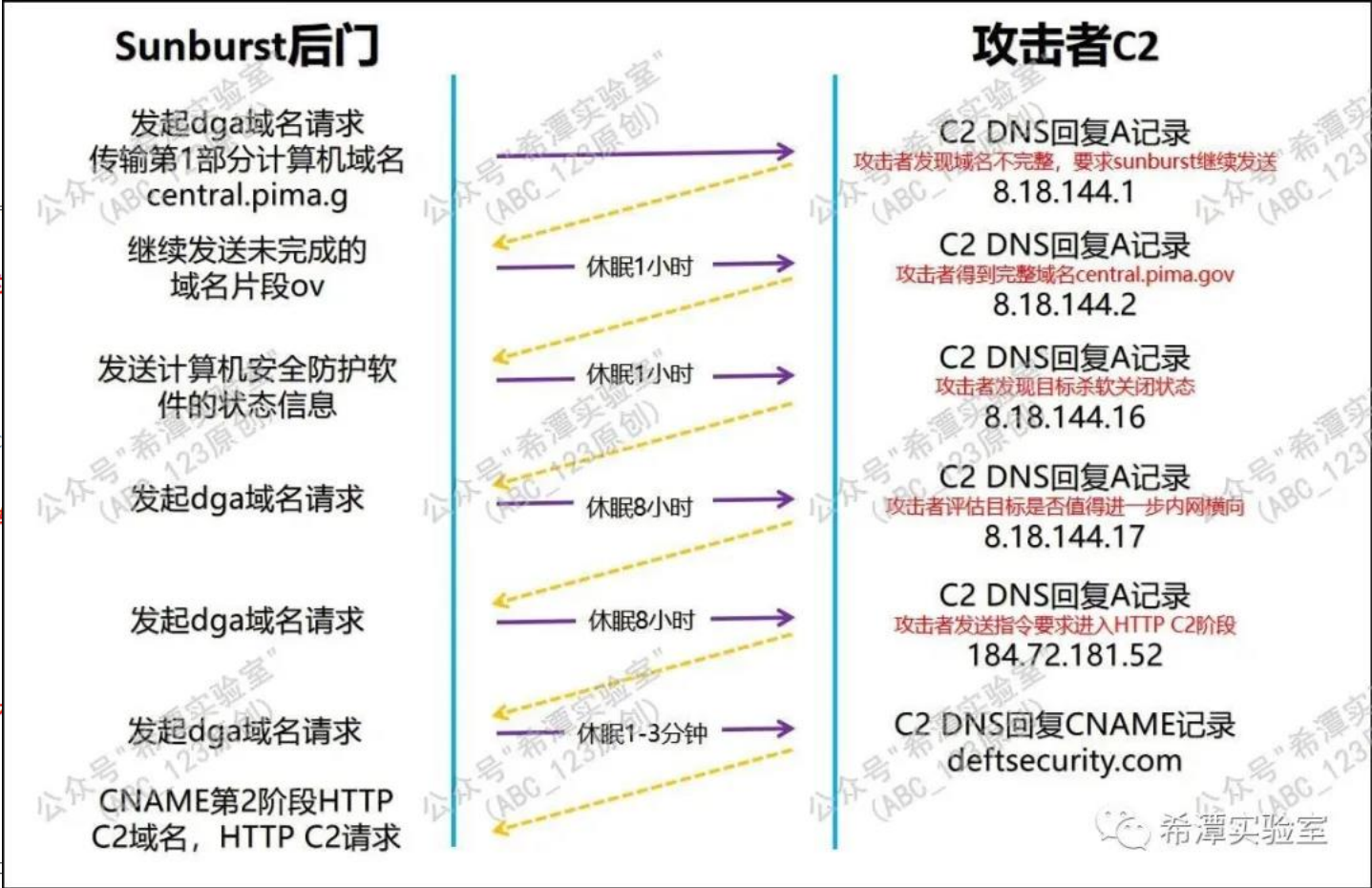
Sunburst发起查询：p50jllhvhmoti8mpbf6p2di.appsync-api.us-west-2.avsvmcloud.c
无可报告。
响应：8.18.144.16 ⇒ Sunburst后门休眠 8 小时，然后继续（此时攻击者知道，目标的防护处于关闭状态）。

第4步 2020-06-11 14:00 UTC

Sunburst发起查询：(?) ⇒ 没有新的报告
响应：8.18.144.17 ⇒ Sunburst后门休眠 8 小时，然后继续（此时攻击者在评估该目标是否值，是否值得进一步渗透）。

第5步 2020-06-11 22:35 UTC

Sunburst发起查询：j5uqlssr1hfqnn8hkf172mp.appsync-api.us-west-2.avsvmcloud.c
无需报告
响应：184.72.181.52 ⇒ Sunburst休眠1-3 分钟（解析到该IP地址，Sunburst将会准备进入第2阶段HTTP C2阶段）



根据DNS解析到不同IP地址控制后门的操作

IP地址范围	Sunburst对应的操作行为
8.18.144.0/23 71.152.53.0/24 87.238.80.0/21 199.201.117.0/24	一般用于HTTP C2开始之前, 说明攻击者还未决定是否对连接进行, 让中间人攻击。如果尚未发送完所有的 Windows 域完整的域名片段发送完毕, Sunburst 全软件状态信息。
18.130.0.0/16 99.79.0.0/16 184.72.0.0/15	设置第2阶段标志, 将源码中的rec信息, 则继续发送。攻击者会对DNS CNAME不为空, 于是将CNAME域进入第三阶段HTTP C2阶段。
20.140.0.0/15 96.31.172.0/24 131.228.12.0/22 144.86.226.0/24	Sunburst的工作状态转为“Trunc注册表项, 清除感染痕迹, 然后退
41.84.159.0/24 74.114.24.0/21 154.118.140.0/24 217.163.7.0/24	Sunburst由“Append”状态变为
10.0.0.0/8 172.16.0.0/12 192.168.0.0/16 224.0.0.0/3 fc00:: - fe00:: fec0:: - ffc0:: ff00:: - ff00::	Sunburst的工作状态转为“Trunc境, 如果DNS请求解析的ip地址是

时间	dga域名查询/响应	解密请求
2020-07-04 00:03	lf9prvp9o36mhihw2hrs260g12eu1 .appsync-api.eu-west-1.avsvmcloud.com 8.18.145.139	计算机域名"omeros.local" 延迟1小时, 然后继续
2020-07-04 01:08	hnhb3v1b37dvv09icgOedp0 8.18.145.62	发现Carbon Black终端防护 延迟1天, 然后继续
2020-07-05 01:15	ea99hr2sfen95nkjlc5g 8.18.144.150	PING请求 延迟1天, 然后继续
2020-07-06 02:42	707gigk9vbc923hf27fe 8.18.145.	PING请求 延迟1天, 然后继续
2020-07-07 03:52	6eivqct649pcg0g16ol4 20.140.84.127	PING请求 停止DNS请求

HTTP C2通信阶段（获取攻击指令并执行）

研发Sunburst后门的攻击者，为了过流量监控，在这个阶段设计了极为巧妙的流量加密方法，接下来ABC_123给大家具体说一下，让大家开开眼界。

首先贴出在HTTP C2通信阶段Sunburst后门的3种不同的URL访问形式，分别对应着3种情况：

1. Sunburst会不断访问.xml网址，主动获取C2端的指令，URL形式如下：

hxxps://3mu76044hgf7shjf.appsync-api.eu-west-1.avsvmcloud.com/swip/upd/Orion.Wireless.xml

2. Sunburst将指令执行结果返回C2端，数据大于10,000时，URL形式如下：

hxxps://3mu76044hgf7shjf.appsync-ap.us-east-2.avsvmcloud.com/pki/crl/492-ca.crl

3. Sunburst将指令执行结果返回C2端，数据小于等于10,000时，URL形式如下：

hxxps://3mu76044hgf7shjf.appsync-api.us-east-1.avsvmcloud.com/fonts/woff/6047-freefont-ExtraBold.woff2

发起HTTP请求向C2的.xml地址请求指令

https[:]//infinitysoftwares.com/swip/upd/SolarWinds.CortexPlugin.Nodes-5.2.1.xml

https[:]//infinitysoftwares.com/swip/upd/Orion.Wireless.UI-3.1.0.xml

https[:]//infinitysoftwares.com/swip/upd/Nodes-1.2.0.xml

Wireshark · Follow TCP Stream (tcp.stream eq 0) · 2.pcap

GET /swip/upd/Orion.UI-5.2.0.xml HTTP/1.1
If-None-Match: df[redacted] 5f
Host: [redacted]
Connection: Close

HTTP/1.1 200 OK
Content-Type: application/xml
Transfer-Encoding: chunked
Connection: close
Server: Microsoft-IIS/10.0
X-AspNet-Version: 4.0.30319
X-Trace: 2B [redacted]
X-Powered-By: ASP.NET
Date: [redacted]
ETag: fee [redacted] cd11f

1eea
<?xml version="1.0" encoding="utf-8"?>
<assembly Name="Orion.UI" Key="{28 [redacted] 0-dcc8-471b-5
 <dependencies>
 <assemblyIdentity Name="Microsoft.Threading.
 fabb-[redacted]" Version="1.0.165.0" Culture="neu
 Hash="36[redacted] a472"/>
 <assemblyIdentity Name="SolarWinds.DPI.Commo
 Culture="neutral" PublicKeyToken="72273be33fabb7b3"
 <assemblyIdentity Name="SolarWinds.Orion.Cor
 }" Version="3.0.0.3149" Culture="neutral
 Hash="d4d7c77166aa1b24ecd8a5426d80141e"/>
 <assemblyIdentity Name="SolarWinds.Wireless.
 Version="3.3.0.454" Culture="neutral" PublicKeyToken
 <assemblyIdentity Name="SolarWinds.Data.Providers.vim.Plugin.v3
 Version="8.3.1.8604" Culture="neutral" PublicKeyToken=" [redacted] Hash=" [redacted] 7">
 <assemblyIdentity Name="Infragistics2.Win.Misc.v10.2" Key="{ [redacted] }

第1分段	第2分段	第3分段	4	第5分段	第6分段	第7分段	8	9
/swip/upd/.	SolarWinds.	CortexPlugin.	Orion.	Wireless. UI. Widgets. CloudMonitoring. NPM. Apollo. gluonhq.com.	Nodes- Volumes- Interfaces- Components-	<1,19>. <1,29>	error code	.xml
概率100%含有 (固定值)	随机取到的概率为20%	随机取到的概率为40%	概率80%	6选1, 随机取到的概率为80%, 可为空	4选1, 随机取到的概率为30%, 可为空	30%	概率100%, 取值0或1	概率100%

希潭实验室

Sunburst后门向C2回传命令执行结果

hxxps://3mu76044hgf7shjf.appsync-api.us-east-1.avsvmcloud.com/fonts/woff/6047-freefont-ExtraBold.woff2

```
PUT /fonts/woff/6047-freefont
Host: defsecurity.com
Content-type: application/javascript
Content-Length: 778

{
  "userId": "bbdbeb8b-9b17-429d-8be5-32d15689b48e",
  "sessionId": "186510dc-be7a-4f4f-a76d-f254052d4a31",
  "steps": [
    {
      "Timestamp": "/Date(1610761481000)/",
      "Index": 0,
      "EventType": "Orion",
      "EventName": "EventMail",
      "DurationMs": 346,
      "Succeeded": true,
      "Message": "MDdjZmRiMjY2RkZWU="
    },
    {
      "Timestamp": "/Date(1610761481000)/",
      "Index": 1,
      "EventType": "Orion",
      "EventName": "EventMail",
      "DurationMs": 34,
      "Succeeded": true,
      "Message": "YzBkMTY2RkZWU="
    },
    {
      "Timestamp": "/Date(1610761481000)/",
      "Index": 2,
      "EventType": "Orion",
      "EventName": "EventMail",
      "DurationMs": 123,
      "Succeeded": true,
      "Message": "ZmZhYWQxMTY2RkZWU="
    }
  ]
}
```

"userId": "bbdbeb8b-9b17-429d-8be5-32d15689b48e" ← 目标计算机的userId
"sessionId": "186510dc-be7a-4f4f-a76d-f254052d4a31" ← 每个http请求随机生成的sessionId
"steps": [

第1分段	第2分段	第3分段	第4分段	第5分段	第6分段	第7分段
/fonts/woff/	<100,9999>	-opensans -noto	-Bold -BoldItalic -ExtraBold -ExtraBoldItalic -Italic -Light -LightItalic -Regular -SemiBold -SemiBoldItalic	-webfont	<error code>	.woff2
固定不变的值	取值是100到10000的随机数	以上2选1	内置字符串列表随机选择一个，10选1	固定不变的值	上一次请求的错误码	固定不变的后缀

"Message": "ZmZhYWQxMTY2RkZWU="

3 传统方法及机器学习对DGA域名的识别



Solarwinds供应链攻击中DGA域名列表

肉眼可见存在一定的规律。
DGA常用于恶意软件生成大量
随机域名进行通信，从而躲避
传统基于域名的检测方法。

程序会根据域名的不同特征（
例如字符类型、字母是否连续
、数字出现的频率等）为每个
域名赋予一个分数。得分越高
，说明域名越有可能是由DGA
算法生成的。此外，程序还会
将域名与已知的恶意域名黑名
单进行比对，如果域名匹配黑
名单中的条目，将直接标记为
恶意域名。

882	q1b91c4fdd7q4td56rswoiou0govirsv.appsinc-api.us-east-1.avsvmcloud.com	servitia.intern
883	q3b8h3lm9q7eoqa56260kun0e6iuir0e.appsinc-api.us-east-2.avsvmcloud.com	sos-ad.state.
884	q3vcrhhcmddh7rl5oi602ou6iuir0grn.appsinc-api.us-east-2.avsvmcloud.com	its.iastate.ed
885	q80cgv4eolosbfo4tvef0t12eu1.appsinc-api.us-east-1.avsvmcloud.com	gncu.local
886	q882csbrq50a58d4r6eud0i2st.appsinc-api.us-east-1.avsvmcloud.com	escap.org
887	q8bps26mocuq6re4dutr0ct2w.appsinc-api.us-east-1.avsvmcloud.com	pageaz.gov
888	q8g11thobvg6d604tvef0b12eu1.appsinc-api.us-east-1.avsvmcloud.com	gncu.local
889	sf0q84qdutb323q6eo6e202e2h.appsinc-api.us-east-1.avsvmcloud.com	cisco.com
890	q8vmaei8n3dpeui5vr2d32i2voe60be2.appsinc-api.us-east-1.avsvmcloud.com	neophotonics.co
891	qb9it88vftri6v84euheoip0e12eu1.appsinc-api.us-west-2.avsvmcloud.com	camcity.local
892	qbj26i5jnkrqdac5wh602un0twusouv0.appsinc-api.us-west-2.avsvmcloud.com	vms.ad.varian
893	1cmge6dsc1rtfj6e0gdohu0et2w.appsinc-api.us-east-1.avsvmcloud.com	sc.pima.gov
894	qfnf6ab6u28je4d5un0b2dioho7r1p0b.appsinc-api.us-east-2.avsvmcloud.com	ad.optimizely.
895	qfnf6ab6u28je4i5un0c2dioho7r1p0c.appsinc-api.us-east-2.avsvmcloud.com	ad.optimizely.
896	qg1e4bctbk3gdkr4e2sd0bdieo0be2h.appsinc-api.us-east-1.avsvmcloud.com	corp.ptci.com
897	qgc2gj97t3sop4i5uhs0be2sd0govir1.appsinc-api.us-east-1.avsvmcloud.com	amr.corp.intel
898	qgdubroda1vph414srd6sw0oe2h.appsinc-api.us-east-1.avsvmcloud.com	repsrv.com
899	qipotpf1jic4gav5oi60eou6iuir0grn.appsinc-api.us-east-2.avsvmcloud.com	its.iastate.ed
900	qit94i5tqf2j9mq5wo11r02irssrc2vv.appsinc-api.us-east-2.avsvmcloud.com	ville.terrebonn
901	qj1bggoa06prfj646d6n0g6j02eu.appsinc-api.us-east-1.avsvmcloud.com	spsd.sk.ca
902	qj82njdvtfuoi455uhs0be2sd0govir1.appsinc-api.us-east-1.avsvmcloud.com	amr.corp.intel
903	qo046rspifbl4k04e2mvri0ge2m0te2h.appsinc-api.us-east-2.avsvmcloud.com	coxnet.cox.com
904	qrrio21mr659tfk5wh60iun0bwusouv0.appsinc-api.us-west-2.avsvmcloud.com	vms.ad.varian
905	qrjtdj3alnclj0k4urso2ve2sd0be2h.appsinc-api.us-west-2.avsvmcloud.com	aerioncorp.com
906	qvot463cl5rcg5r4urso2ve2sd02e2h.appsinc-api.us-west-2.avsvmcloud.com	aerioncorp.com
907	r14ptgkl7qacucu5chsv0ee2h.appsinc-api.us-west-2.avsvmcloud.com	bmrn.com
908	r1q6arhpujcf6jb6ervisu10odohu0it.appsinc-api.us-west-2.avsvmcloud.com	central.pima.g
909	r1qshoj05ji05ac6eoip02jovt6i2v0c.appsinc-api.us-west-2.avsvmcloud.com	city.kingston.
910	r69ncekf56jllkr6oi602ou6iuir02rn.appsinc-api.us-east-2.avsvmcloud.com	its.iastate.ed
911	r6b5cj43deojp665u30c2st.appsinc-api.us-east-2.avsvmcloud.com	ah.org
912	r74br8r0cce4m6r6oi60eou6iuir0trn.appsinc-api.us-east-2.avsvmcloud.com	its.iastate.ed
913	r75n0q0557bl6nv6oi60cou6iuir0orn.appsinc-api.us-east-2.avsvmcloud.com	安全客 (www.anquanke.com)
914	r7kqk893t5lu82j6uhs0ie2sd0iovir1.appsinc-api.us-east-2.avsvmcloud.com	amr.corp.intel

传统的DGA域名识别算法

辅音与数字的组合：如果一个域名包含多个连续的辅音字母或数字，它会被认为是DGA域名的一个特征。

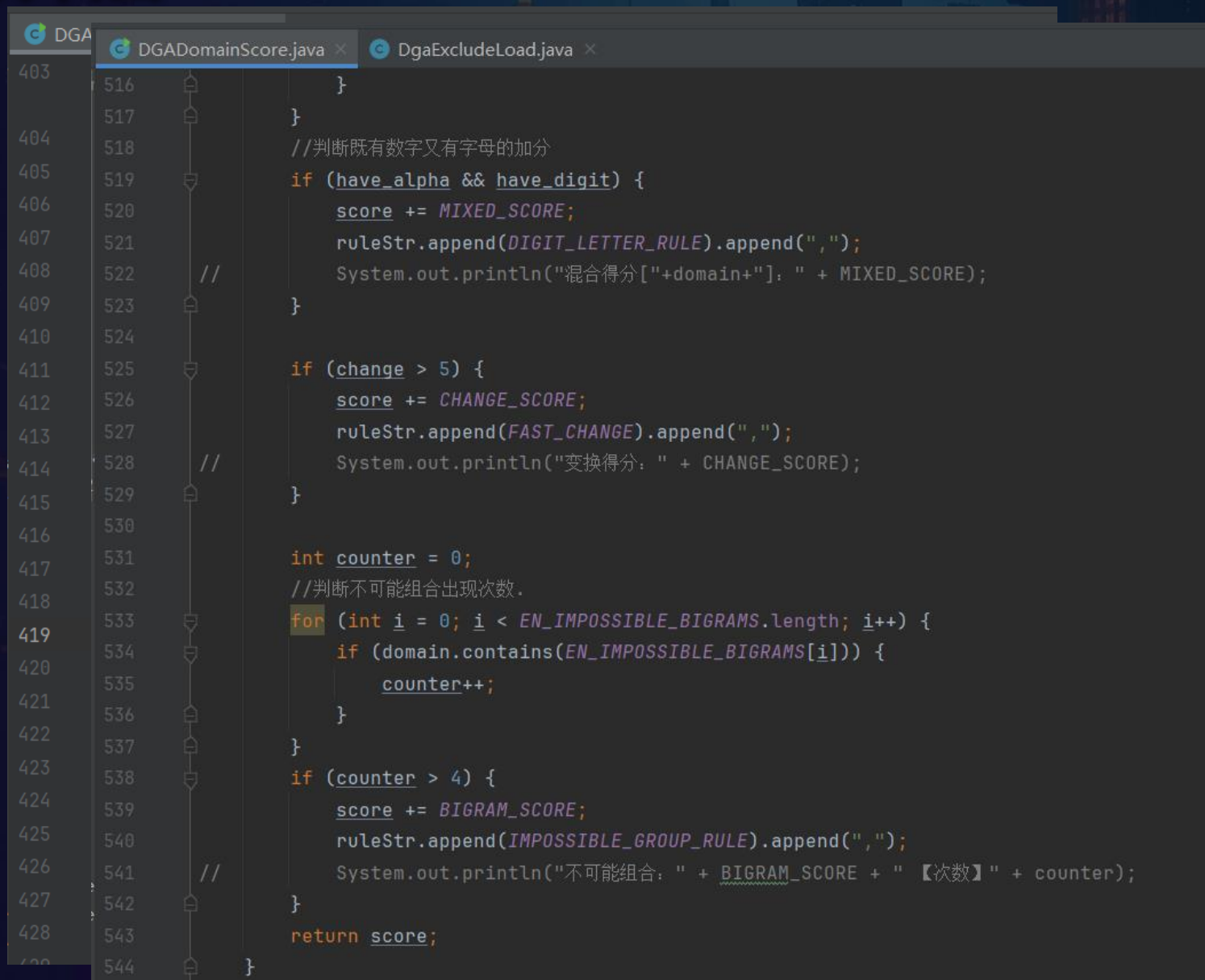
混合得分：如果一个域名同时包含数字和字母的混合，这也会增加其得分。

不可能的大写字母组合：域名中包含某些

不常见的字母组合（如bk、fq等），也会加分。DGA生成的域名往往包含这些不常见的字母组合。

域名长度：域名的长度过长或过短也会影响分数，通常DGA域名的长度较为固定。

域名后缀检查：DGA域名通常会使用不常见的顶级域名，程序会检查是否为.com、.net、.org等常见后缀。

A screenshot of a code editor with two tabs: 'DGADomainScore.java' and 'DgaExcludeLoad.java'. The 'DGADomainScore.java' tab is active, showing Java code for calculating domain scores. The code includes comments in Chinese and various conditional checks for domain characteristics like mixed letters and digits, impossible bigrams, and domain length. The code is line-numbered from 403 to 544. The editor has a dark theme with a sidebar on the left showing a file tree.

```
403 516 }
404 517 }
405 518 //判断既有数字又有字母的加分
406 519 if (have_alpha && have_digit) {
407 520     score += MIXED_SCORE;
408 521     ruleStr.append(DIGIT_LETTER_RULE).append(",");
409 522     System.out.println("混合得分["+domain+"]: " + MIXED_SCORE);
410 523 }
411 524
412 525 if (change > 5) {
413 526     score += CHANGE_SCORE;
414 527     ruleStr.append(FAST_CHANGE).append(",");
415 528     System.out.println("变换得分: " + CHANGE_SCORE);
416 529 }
417 530
418 531 int counter = 0;
419 532 //判断不可能组合出现次数。
420 533 for (int i = 0; i < EN_IMPOSSIBLE_BIGRAMS.length; i++) {
421 534     if (domain.contains(EN_IMPOSSIBLE_BIGRAMS[i])) {
422 535         counter++;
423 536     }
424 537 }
425 538 if (counter > 4) {
426 539     score += BIGRAM_SCORE;
427 540     ruleStr.append(IMPOSSIBLE_GROUP_RULE).append(",");
428 541     System.out.println("不可能组合: " + BIGRAM_SCORE + " 【次数】" + counter);
429 542 }
430 543 return score;
431 544 }
```

传统的DGA域名识别算法

连续数字或字母的组合：如果域名中有长串连续数字或辅音字母，则会加分。

辅音和数字计数：程序遍历域名字符，统计辅音字母和数字的连续出现次数。如果辅音字母或数字连续出现的次数超过了预定的阈值，会加分。

元音字母检查：如果域名中的元音字母较少，可能会增加得分。

大写字母组合：某些不常见的字母组合会被认为是DGA特征，增加得分。

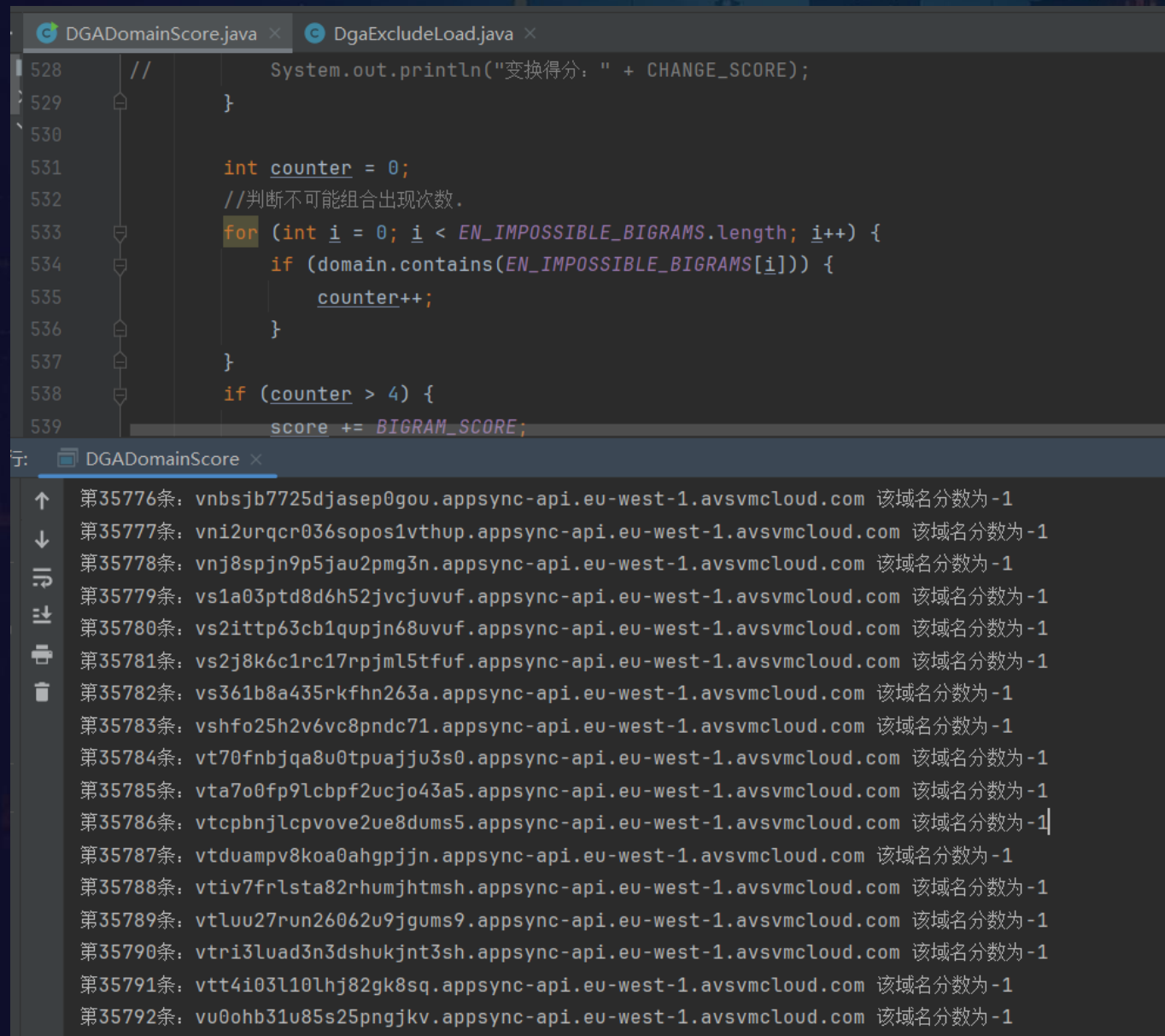
```

DGADomainScore.java x DgaExcludeLoad.java x
435 //域名xn--开头的一般正常
DGADomainScore.java x DgaExcludeLoad.java x
456 return -1;
457 }
458 //域名拆分,进行数字,字母出现次数等分数加值.
459 char[] chs = domain.toCharArray();
460 for (int i = 0; i < chs.length; i++) {
461     if (Character.isDigit(chs[i])) { //是数字
462         if (digit_flag) {
463             continue;
464         }
465         have_digit = true; //有数字
466         if (last == DIGIT) {
467             digit++;
468         } else {
469             if (last == CONSO) {
470                 change++;
471             }
472             digit = 0;
473         }
474         //连续数字超过 初始化值的数量, 直接加连续数字的分值, 并且修改digit_flag=true以后的字符不在执行逻辑判断
475         if (digit >= digit_count) {
476             score += DIGIT_SCORE;
477             ruleStr.append(CONTINUOUS_DIGIT_RULE).append(",");
478             digit_flag = true;
479         }
480         last = DIGIT;
481         //是字母
482     } else if (Character.isLetter(chs[i])) {
483         if (conso_flag) {
484             continue;
485         }
486         have_alpha = true;
487         have_digit = true; //有数字

```


传统算法识别结果

可以检测大部分的DGA域名，检测困难：由于DGA域名通常是通过算法生成的，且具有高度的随机性，黑名单方法很难应对这种情况。传统的特征设计方法（例如基于字符串的分析）也存在困难，因为这些特征随着DGA种子的变化而变化。



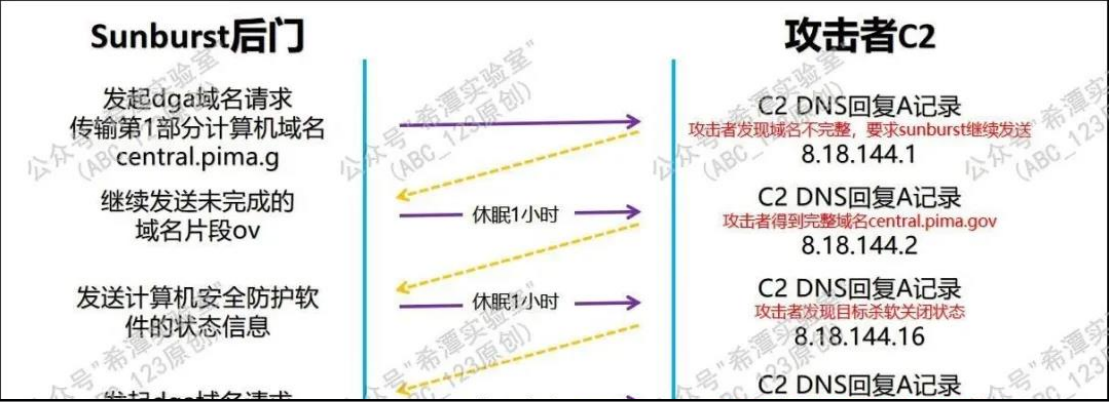
```
DGADomainScore.java x DgaExcludeLoad.java x
528 // System.out.println("变换得分: " + CHANGE_SCORE);
529 }
530
531 int counter = 0;
532 //判断不可能组合出现次数.
533 for (int i = 0; i < EN_IMPOSSIBLE_BIGRAMS.length; i++) {
534     if (domain.contains(EN_IMPOSSIBLE_BIGRAMS[i])) {
535         counter++;
536     }
537 }
538 if (counter > 4) {
539     score += BIGRAM_SCORE;
```

行: DGADomainScore x

- 第35776条: vnbsjb7725djasep0gou.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35777条: vni2urqcr036sopos1vthup.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35778条: vnj8spjn9p5jau2pmg3n.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35779条: vs1a03ptd8d6h52jvcjuvuf.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35780条: vs2ittp63cb1qupjn68uvuf.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35781条: vs2j8k6c1rc17rpjml5tfuf.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35782条: vs361b8a435rkfhn263a.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35783条: vshfo25h2v6vc8pndc71.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35784条: vt70fnbjqa8u0tpuajju3s0.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35785条: vta7o0fp9lcbpf2ucjo43a5.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35786条: vtcpbjnlcpvove2ue8dums5.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35787条: vtduampv8koa0ahgpjjn.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35788条: vtiv7frlsta82rhumjhtms.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35789条: vtluu27run26062u9jgums9.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35790条: vtri3luad3n3dshukjnt3sh.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35791条: vtt4i03l10lhj82gk8sq.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1
- 第35792条: vu0ohb31u85s25pngjkv.appsync-api.eu-west-1.avsvmcloud.com 该域名分数为-1

尝试LSTM模型结合Attention机制

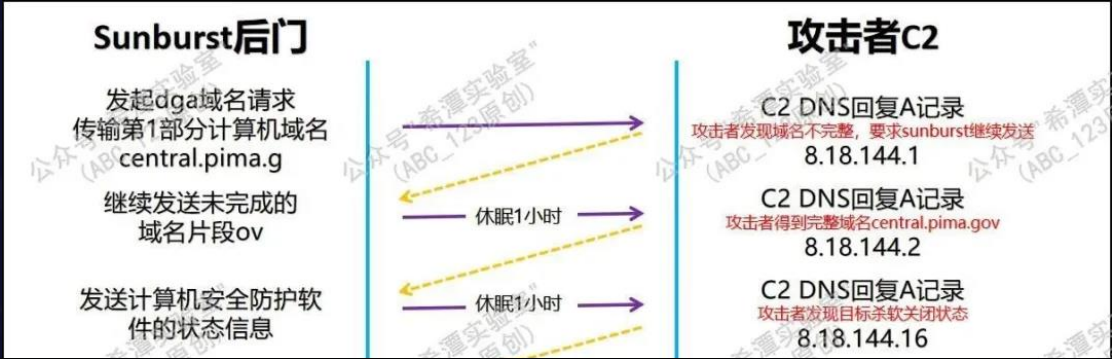
依赖于深度学习中的LSTM (Long Short-Term Memory) 模型，并结合了Attention机制来提高检测的精度和效率。将Attention机制加入到LSTM中。这一组合可以帮助LSTM更加灵活地关注输入序列中不同部分的信息，从而提高对DGA域名的检测能力。在模型的输出时，Attention机制帮助模型根据输入序列的重要性加权计算输出，提高了模型的准确性。



时间	dga域名查询/响应	解密请求
2020-07-04 00:03	lf9prvp9o36mhihw2hrs260g12eu1 .appsync-api.eu-west- 1.avsvmcloud.com 8.18.145.139	计算机域名"omeros.local" 延迟1小时, 然后继续
2020-07-04 01:08	hnhb3v1b37dvv09icgOedp0 8.18.145.62	发现Carbon Black终端防护 延迟1天, 然后继续
2020-07-05 01:15	ea99hr2sfen95nkjlc5g 8.18.144.150	PING请求 延迟1天, 然后继续
2020-07-06 02:42	707gigk9vbc923hf27fe 8.18.145.	PING请求 延迟1天, 然后继续
2020-07-07 03:52	6eivqct649pcg0g16ol4 20.140.84.127	PING请求 停止DNS请求

应对此APT后门的DGA通信，还是需要大模型解决

Solarwinds供应链攻击案例中，Sunburst后门的DGA域名通信，一天只发一起DGA域名请求，而且avsvmcloud.com人工难以识别其是否是真是恶意攻击。
最终还是需要依靠大模型解决这个难题。



时间	dga域名查询/响应	解密请求
2020-07-04 00:03	lf9prvp9o36mhihw2hrs260g12eu1 .appsync-api.eu-west- 1.avsvmcloud.com 8.18.145.139	计算机域名"omeros.local" 延迟1小时，然后继续
2020-07-04 01:08	hnhb3v1b37dvv09icgOedp0 8.18.145.62	发现Carbon Black终端防护 延迟1天，然后继续
2020-07-05 01:15	ea99hr2sfen95nkjlc5g 8.18.144.150	PING请求 延迟1天，然后继续
2020-07-06 02:42	707gigk9vbc923hf27fe 8.18.145.	PING请求 延迟1天，然后继续
2020-07-07 03:52	6eivqct649pcg0g16ol4 20.140.84.127	PING请求 停止DNS请求

谢谢

